

让高风险变更， 在合并前停下来

MergePilot：面向 AI Coding 的安全控制面。普通任务自动完成，高危任务人工批准，严重任务安全停止——每一步都有据可查。

WHY NOW · 01

代码能通过测试， 不代表变更是安全的

CONTEXT · 上下文

传统流水线只回答
「能不能跑」

跨仓库影响、历史 Finding、Schema 风险，都不在单元测试的视野里。

PROCESS · 过程

谁做了什么，
有没有绕过权限与人工门

AI 改代码很快，企业不敢让它碰生产环境，卡在「出了事怎么追溯」。

OUTCOME · 结果

MergePilot 还要回答
「该不该合并」

验证失败能否停止，成功是否留下可复核证据——这才是「敢合并」的前提。

01

02

03

三条真实决策路径

THREE PATHS · 不是固定顺序调用

批准能继续，
拒绝能停下，
人工门双向可控

上下文沿 Reviewer → Fixer →
Verifier 传递，分歧回到验证，不直
接跳过人工门。

01

PR #1 · 低风险

自动完成

running → completed。AI 审查 → 修
复 → 验证，全程无人工介入。

02

PR #2 · 高风险 · CWE-22

人工批准后完成

人工门 → approved。探针验证：修
复前 200，修复后 404。

03

PR #3 · 严重风险 · CWE-78

人工拒绝后停止

rejected → terminal。再批准返回
409，拒绝不可翻转。

每一步都有权限、状态和证据

01 发现 · Reviewer

只做语义判断与风险分级 (NORMAL / HIGH / CRITICAL)，不修改代码。

02 修复 · Fixer

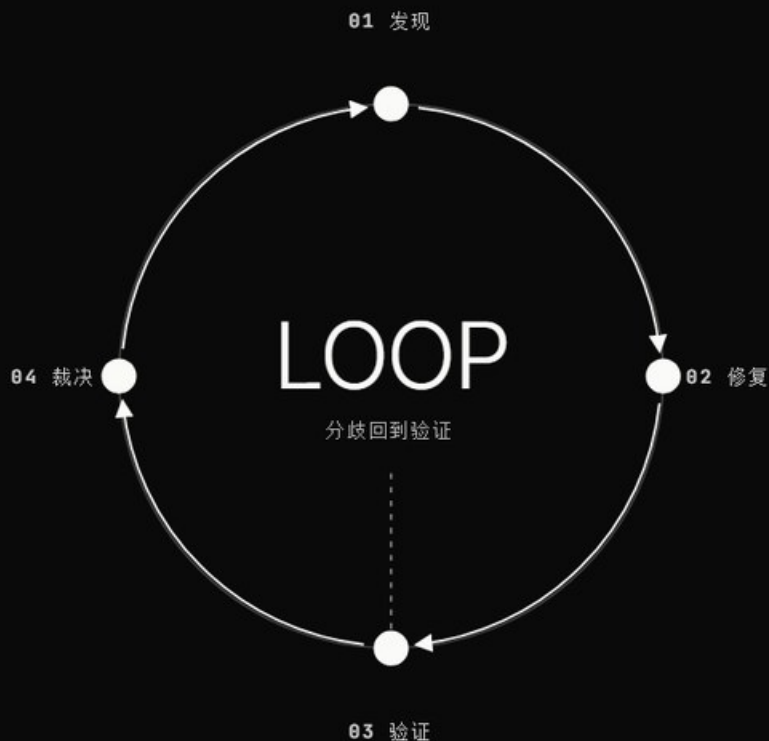
被派发前保持 LOCKED，高危时必须等人工门放行。

03 验证 · Verifier

用独立探针复核修复效果，不信任 Fixer 的自述。

04 裁决 · 人工门

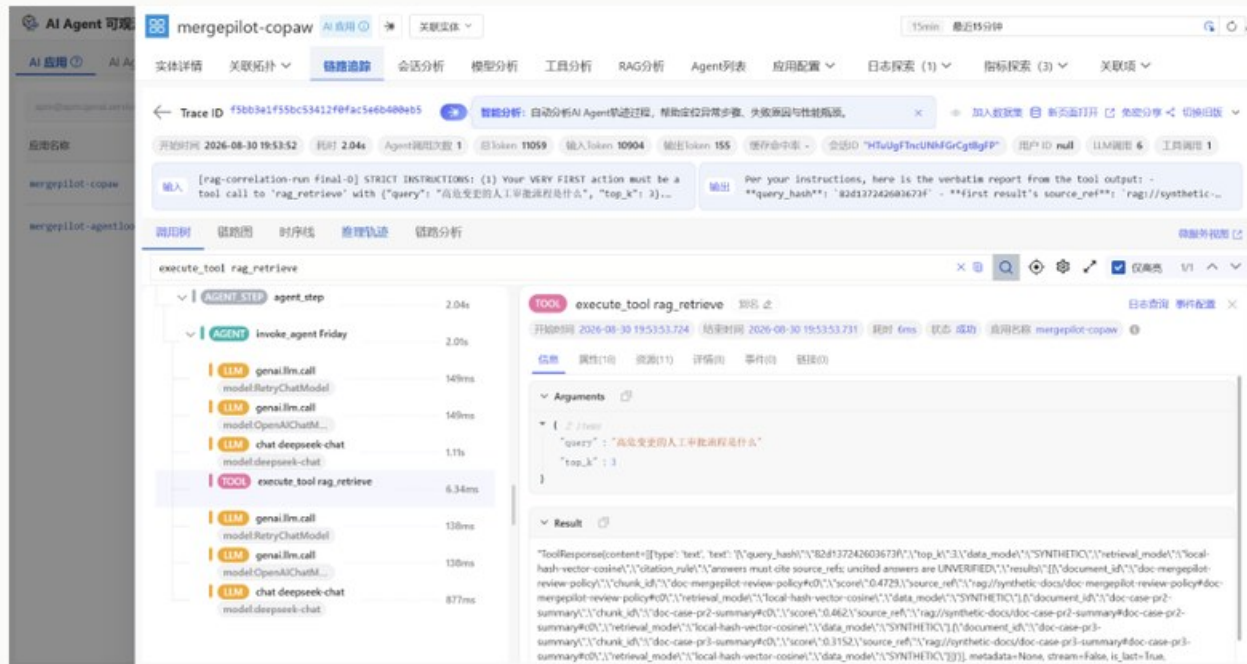
拒绝不是异常：拒绝后状态锁定，回放不可写，后续批准返回 409。



RAG MEMORY · 04

先检索历史经验 再讨论修复方案

`rag_retrieve` 把 Finding、修复案例、审查政策带进当前 PR。
上图不是设计图——这次调用发生在真实 Agent 运行里，与 LLM 调用在同一条云端 Trace 内。语料为 SYNTHEIC 脱敏合成集，不保存原文。



TOOL LATENCY

6ms

execute_tool rag_retrieve ·
状态成功

SAME TRACE

6 + 1

LLM 调用 6 次 · 工具调用 1 次
· 2.04s

TRACE F58B3E1F

11,059

Token 总量 · 08-30 19:53:52
入云

Schema 变更先在隔离 Branch 里验证

3

候选方案 · FastAPI 跨仓案例

candidate-a REJECTED · candidate-b DEGRADED · candidate-c VERIFIED



137

脏数据行

隔离副本上的数据核对结果，失败候选不得 promote



2

重复键冲突

唯一性检查结果，作为拒绝依据写入证据



5 / 5

断言通过 · candidate-c

验证成立，但不自动合并——通过候选仍停在人工门



OBSERVABILITY · 06

Agent、LLM、Tool 在同一条 Trace 里

阿里云 AgentLoop 控制台真实截图：一次真实运行，1 个 Agent、端到端 17.6s，三类 span 合并在同一条链路。演示平台的每个页面状态都来自这次运行记录的回放，事件级可追溯。

Trace fbf4a3cec0493990d76e10a102418be1



LLM CALLS

24

chat deepseek-chat +
genai.llm.call

TOOL CALLS

8

execute_tool ×8 · 含
database_create_branch

TOKENS

51,890

输入 49,867 · 输出 2,023

结果评估和轨迹评估，分开看

OUTCOME · 结果评估

8 / 8

状态、候选、回滚、人工门——最终状态 8 项全部成立，独立成文 (result-evaluation.json)。

TRAJECTORY · 轨迹评估

10 / 10^{*}

工具选择、顺序、证据、停止条件——过程 10 项通过 (trajectory-evaluation.json)。

* 其中 1 项部分成立：DB 工具云端 span——create_branch 已确认入云，其余为本地契约审计。

最终答案正确，不足以证明过程正确。MergePilot 同时保留两套证据。

TRUTHFULNESS · 08

边界写在产品里， 演示不冒充 生产接入

凭据不落盘，证据只读，失败候选不能晋级。真实的是决策与工具执行——云端 Trace 与本地契约审计双重留痕；被模拟的只有数据库本体，因为接入门槛未满足，我们如实披露而不伪装。

RAG 语料

SYNTHETIC / REDACTED

脱敏合成演示集，未接入企业生产语料

DATABASE BRANCH

SIMULATED

隔离模拟环境，真引擎 + 模拟数据库

POLARDB

NOT CONNECTED

8 项接入门槛在代码中预留，切 LIVE 不改代码

PR AUTO MERGE

DISABLED

演示全程零 PR 写操作，54 项自测 + 秘密扫描

MANIFESTO

把「能合并」 变成「敢合并」

三条真实决策路径，一套可回放、可追溯的控制
闭环。AgentTeams + AgentLoop + RAG +
Schema Branch。

01 普通任务自动完成

Reviewer → Fixer → Verifier 全自动，无人工介入。

02 高危任务人工批准后完成

系统自动暂停进入人工门，批准后修复，探针验证 200 → 404。

03 严重任务人工拒绝后安全停止

拒绝终态不可翻转，再批准返回 409——这是故意的安全护栏。